

Authentication & Security

인증과 보안

5 가지 인증 방법, Device flow, API key, AWS GovCloud 지원

Builder ID, IAM Identity Center, Social login, Headless mode

Choi, WooHyung

Prin. Solutions Architect

AWS Korea

whchoi@amazon.com



Agenda

Chapter 03, Authentication & Security

- | | |
|----|--|
| 01 | 5 가지 인증 방법 개요
Google / GitHub / Builder ID / Organization / API Key |
| 02 | 개인 인증, Social & Builder ID
Google, GitHub, AWS Builder ID, 브라우저 기반 흐름 |
| 03 | 조직 인증, IAM Identity Center
Enterprise SSO, AWS GovCloud (US) 지원 |
| 04 | Device Flow, 원격 환경
SSH, SSM, 컨테이너, 포트 포워딩 불필요 |
| 05 | API Key 인증, Headless
KIRO_API_KEY, Pro / Pro+ / Power 전용 |
| 06 | 인증 우선순위와 관리
Precedence, whoami, login, logout |
| 07 | 보안 베스트 프랙티스
API key 보관, 로테이션, 감사 로그 |

5 가지 인증 방법 개요

AUTHENTICATION METHODS AT A GLANCE

AUTHENTICATION OVERVIEW

Kiro CLI 는 개인 사용자부터 엔터프라이즈, CI/CD 자동화까지 모두 지원하는 5 가지 인증 방법을 제공합니다. 사용 환경과 보안 요구사항에 따라 적절한 방법을 선택합니다.

인증 방법	대상	사용 환경	특징
Google	개인	Local	Social 로그인, 가장 간편
GitHub	개인	Local	Social 로그인, 개발자 친화
Builder ID	개인	Local	AWS 계정 없이도 사용 가능
Organization	조직	Enterprise	IAM Identity Center, GovCloud 지원
API Key	자동화	CI/CD	Pro/Pro+/Power, Headless 전용

5 가지

지원 인증 방법

Browser

기본 인증 흐름

Device

원격 환경 옵션

API Key

Headless 옵션

개인 인증, Social Login & Builder ID

INDIVIDUAL SUBSCRIBER AUTHENTICATION

INDIVIDUAL AUTHENTICATION

개인 구독자는 Google, GitHub, 또는 AWS Builder ID 중에서 선택해 로그인.

모두 브라우저 기반이며 동일한 흐름으로 진행.

GOOGLE

Google 계정으로 로그인

기존 Google 계정으로 즉시 시작.

가장 간편한 옵션으로 별도 가입 절차가 없음.

Kiro Free Tier 부터 사용 가능.

GITHUB

GitHub 계정으로 로그인

개발자 친화 옵션.

GitHub 계정과 자연스럽게 통합되며, MCP
통한 GitHub repo 작업과 시너지가 큼.

BUILDER ID

AWS Builder ID 로 로그인

AWS 가 발급하는 개발자 식별자.

AWS 계정이 없어도 사용 가능.

AWS 서비스와의 통합 시 유리.

3 옵션

개인 인증 방법

Browser

공통 인증 흐름

Free Tier

지원 시작 등급

kiro-cli

첫 실행 명령

조직 인증, IAM Identity Center

ENTERPRISE SSO WITH AWS GOV CLOUD SUPPORT

ORGANIZATIONAL AUTHENTICATION

엔터프라이즈는 IAM Identity Center 를 통한 SSO 로그인 사용.

AWS GovCloud (US) 리전도 동일한 방식으로 지원하며, 시작 URL 에 us-gov-home 포함 여부로 구분.

STANDARD COMMERCIAL

일반 AWS 조직 인증

IAM Identity Center 통한 SSO 로그인

회사의 SSO ID 와 Kiro 계정 자동 매핑

조직 시작 URL 사용

관리자가 정책 / 권한 / 사용량 통제

GOV CLOUD (US) - 한국은 해당사항 없음

정부 및 규제 산업 환경

us-gov-home 시작 URL 사용

IAM Identity Center 전용, Social 미지원

Kiro IDE 0.9.2+ 또는 CLI 1.25.0+ 필요

트래픽 자동으로 GovCloud 리전으로 라우팅

SSO

조직 인증 표준

us-gov-home

GovCloud 식별 URL

1.25.0+

GovCloud 최소 CLI

Org policy

권한과 사용량 통제

Device Flow, 원격 환경 인증

AUTH WITHOUT A LOCAL BROWSER

DEVICE FLOW

원격 머신 (SSH, SSM, 컨테이너) 에서 Kiro CLI 를 실행할 때 사용하는 인증 방식.

원격 머신은 브라우저를 열 수 없으므로 URL 과 일회용 코드를 표시하고 사용자가 다른 디바이스에서 인증을 완료.

STEP 1

kiro-cli login 실행

원격 머신에서 로그인 명령을 실행하고 인증 방법을 선택.

STEP 2

URL 과 일회용 코드 표시

CLI 가 URL 과 one-time code 를 화면에 출력.

STEP 3

다른 디바이스에서 URL 열기

로컬 PC, 폰, 태블릿 등 브라우저가 있는 디바이스에서 URL 을 오픈.

STEP 4

코드 입력 후 인증

코드 입력과 인증 완료 후 CLI 가 자동으로 성공을 감지.

SSH OK

원격 환경 지원

포트 X

포트 포워딩 불필요

4 방법

Builder ID / Org / Social

외부 IdP

현재 미지원

API Key 인증, Headless Mode

FOR CI/CD AND AUTOMATION

API KEY AUTHENTICATION

CI/CD 파이프라인과 자동화 스크립트용 인증 방법./ 브라우저 로그인 대신 환경 변수 KIRO_API_KEY 로 인증.

Pro, Pro+, Power 구독자만 사용 가능하며, 관리자가 활성화해야 사용 가능.

GENERATE

API Key 생성 절차

1. app.kiro.dev 로그인, Pro 이상 계정
2. API Keys 메뉴 진입
3. Create new key, 의미 있는 이름 부여
4. 전체 키 값은 생성 시점에만 표시

USE

환경 변수와 사용 방법

1. `export KIRO_API_KEY=sk_xxxxxxxxx`
2. `kiro-cli chat --no-interactive prompt`
3. Headless 모드에서만 동작
4. 사용 credit 은 구독 credit 에서 차감

Pro+

사용 가능 최소 등급

sk_

API key 접두사

Long-lived

credential 수명

Headless

지원 모드

인증 우선순위와 관리 명령

PRECEDENCE, LOGIN, LOGOUT, WHOAMI

AUTHENTICATION PRECEDENCE

여러 자격증명이 동시에 존재할 때 Kiro CLI 가 어느 것을 사용할지 결정하는 우선순위 규칙. 의도하지 않은 인증 사용을 막으려면 이 순서를 이해해야 합니다.

PRECEDENCE ORDER

우선순위 (위가 최우선)

1. 활성 브라우저 세션, kiro-cli login
2. KIRO_API_KEY 환경 변수
3. 자격증명 없음, sign-in 프롬프트
4. 확인 명령- kiro-cli whoami

MANAGEMENT COMMANDS

인증 관리 명령

1. kiro-cli login 새 브라우저 로그인
2. kiro-cli logout 토큰 제거
3. kiro-cli whoami 현재 인증 확인
4. unset KIRO_API_KEY env 변수 해제

3 단계

우선순위 레벨

Browser

최우선 인증

env var

두 번째 우선

whoami

현재 상태 확인

보안 모범 사례

API KEY HYGIENE AND AUDITING

STORAGE

안전한 보관

.env 파일은 .gitignore 에 추가
secrets manager 사용 권장
평문 commit 금지
CI/CD 변수에 암호화 저장.

ROTATION

주기적 로테이션

조직 정책에 따라 30 또는 90 일 단위
로 키 교체
사용하지 않는 키 즉시 revoke, 이름으
로 사용처 추적 가능.

INCIDENT

유출 대응

유출 시 web console 에서 즉시 revoke
새 키 발급 후 CI/CD 변수 갱신
감사 로그로 사용 흔적 확인이 필요

30 일

권장 로테이션 주기

Revoke

유출 시 즉시 조치

.gitignore

.env 보호 표준

Audit log

사용 흔적 추적

Thank you!

Choi, WooHyung / Prin. Solutions Architect / AWS Korea

whchoi@amazon.com

<https://linkedin.com/in/woohyungchoi>

© 2026, Amazon Web Services, Inc. or its affiliates. All rights reserved. Amazon Confidential and Trademark.

